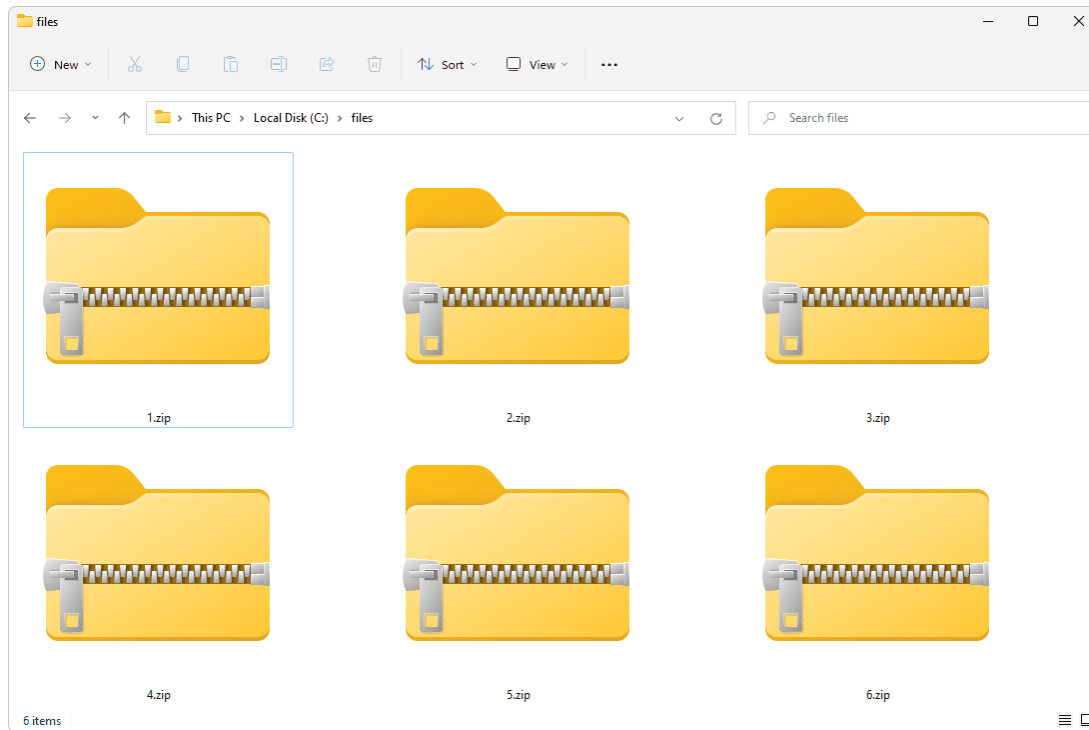

ONLINE.ZIP: THE “.ZIP” TLD AND ITS DANGERS

By: Joe Moran
CS 3170-003
Spring 2025



THE .ZIP FILE FORMAT



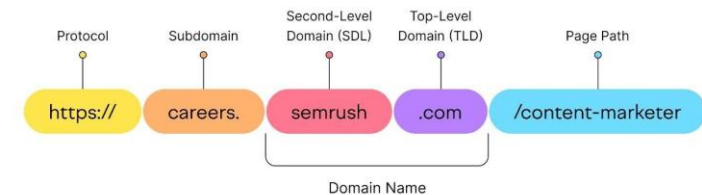
- Archive file format for lossless data compression
- In use since 1989 and included in Microsoft Windows since 2000
- One of the most widely-used and widely-recognized file formats

TLDS AND GTLDS

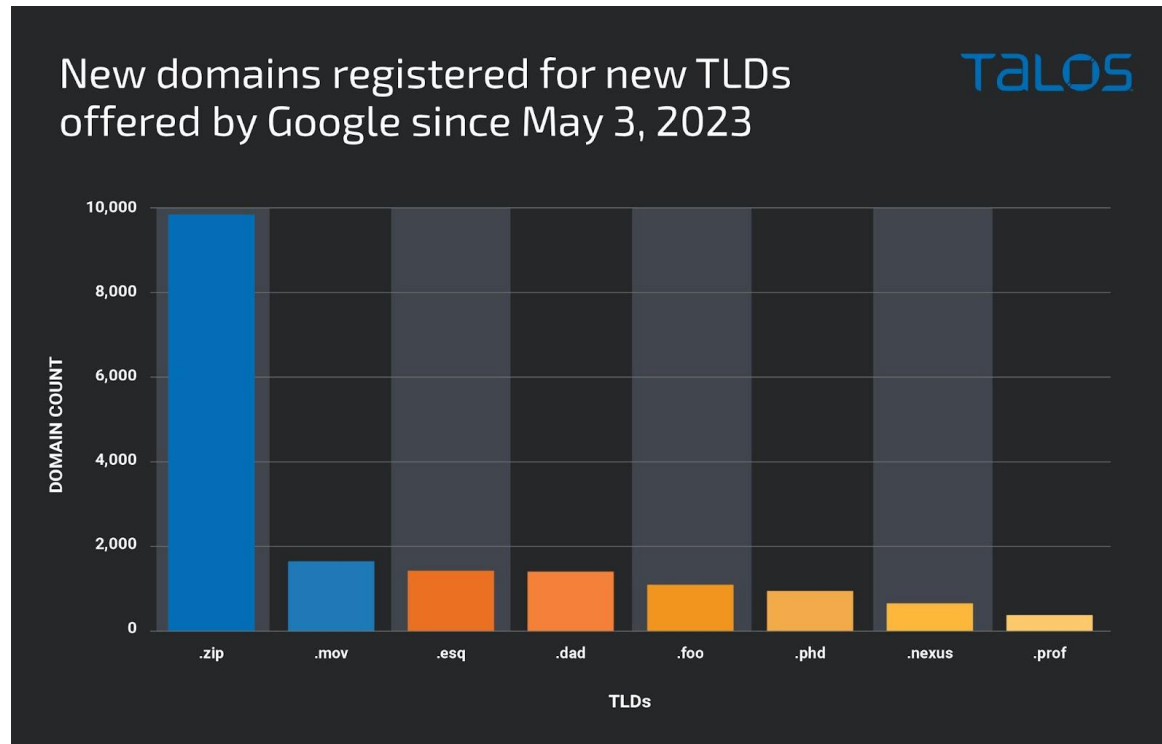
- The domain name is a part of a URL used to access a certain server/authority.
 - Divided into second-level domain (unique per authority) and TLD (general category of usage)
- Top Level Domains (TLDs) are created and assigned by ICANN
 - Internet Corporation for Assigned Names and Numbers
- New gTLDs or Generic Top Level Domains can be applied for by large organizations with ICANN approval, and registration delegated to the organization
 - .biz, .info, .google, .paris, .basketball, .xbox, .george



Parts of a URL



THE .ZIP GTLD



- In 2023 Google registered eight new gTLDs including “.zip” and “.mov”
- The intended purpose of the .zip gTLD is for domains that are “tying things together or moving really fast”
- Cybersecurity researchers quickly pointed out concerns that the .zip domain was the same as the file extension
- Thousands of .zip domains were registered within days of the release, far exceeding the registrations of any of the other new domains

CONFUSION AND PHISHING

- Many of the first domains registered were designed to pass off as signing into a company's website to download a zip file
 - report2023.zip, microsoft-office.zip, login.payment-statement.zip
- Over 200 domains registered in first two weeks contained “installer” or “update” in the domain
 - “chromeupdatex64.zip”, “firefoxinstaller.zip”, “zoom-installer.zip”
- Generic downloads such as “attachment.zip” were also registered
- 42.zip – Downloaded a 4.5PB zip bomb, a reference to one of the first ever zip bombs
- Some domains registered by friendly actors such as googlechrome.zip or bank-statement.zip

Security Notice
<http://bank-statement.zip/>

Security Notice

You've landed on this page because you followed a link for a .zip file. This domain was registered to prevent its misuse for potentially harmful or malicious activities.

Remember, opening unexpected .zip files from unknown sources can put your personal information at risk. Always verify the source and be cautious.

For more information about online safety and how to protect yourself from online threats, consider visiting the following resources:

[Stay Safe Online](#)

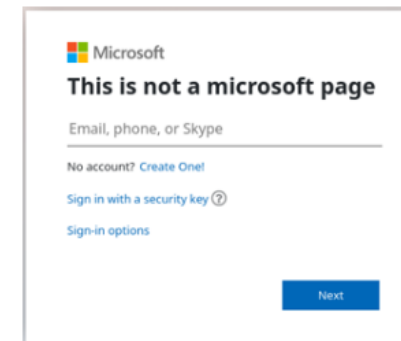
This nonprofit organization provides tools and resources to help users stay safe online, including advice for securing your devices and protecting your personal information.

[Cybersecurity & Infrastructure Security Agency Tips](#)

This government agency offers detailed tips on a variety of cybersecurity topics, from avoiding phishing scams to securing your home network.

[FTC Privacy, Identity & Online Security](#)

The Federal Trade Commission provides comprehensive advice on privacy, identity, and online security, including articles, videos, and infographics.



Microsoft

This is not a microsoft page

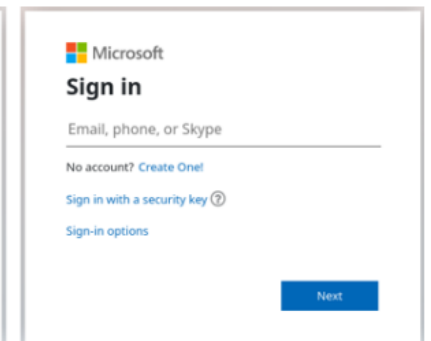
Email, phone, or Skype

No account? [Create One!](#)

[Sign in with a security key](#) ⓘ

[Sign-in options](#)

Next



Microsoft

Sign in

Email, phone, or Skype

No account? [Create One!](#)

[Sign in with a security key](#) ⓘ

[Sign-in options](#)

Next



@trippfives1402 4 years ago

You forgot the main purpose of [42.zip](#). Your antivirus will randomly scan files in the background. This includes zip files. So when your antivirus randomly finds [42.zip](#) in the background in order to scan the contents. This means that just having the file on your computer will cause it to crash over and over as the antivirus keeps trying to scan that file.

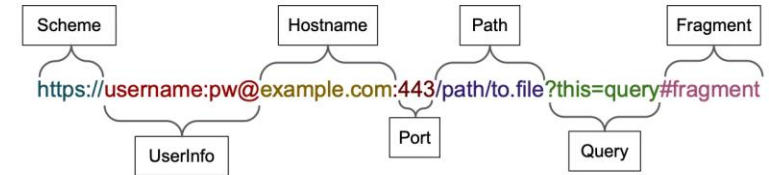
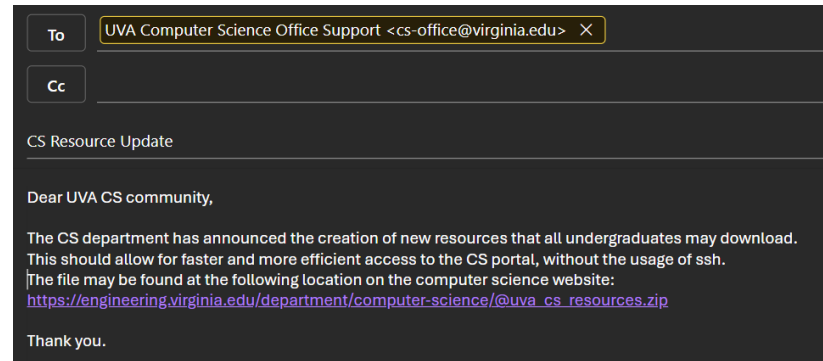


Reply

AUTO- CONVERTED DOMAINS

- Many websites will automatically convert potentially valid links to clickable URLs, even retroactively
- This old YouTube comment discussing the [42.zip](#) zip bomb has been turned into a clickable link to the zip bomb website

REAL VS. FAKE DOMAINS



“https://engineering.virginia.edu/department/computer-science/@uva_cs_resources.zip”

- Protocol
- Ignored (treated as UserInfo section)
- Fake Unicode backslashes
- Actual website you are directed to (potentially malicious)

PROTECTING YOURSELF

- Redirect all .zip namespace links to a safe website in Group Policy Editor
- Block with third-party DNS service (NextDNS)
- General precautions when clicking suspicious links

The screenshot displays the Group Policy Editor interface. On the left, the 'Policies' tree is expanded, with 'Name Resolution Policy' highlighted under 'Windows Settings'. The main pane shows the 'Overview' and 'Create Rules' sections. In the 'Create Rules' section, the 'Suffix' dropdown is set to '.zip'. Below this, the 'Generic DNS Server settings' section is expanded, showing the 'Enable DNS settings' checkbox checked and the 'Generic DNS Server' field set to '127.0.0.1'. The 'DNSSEC' tab is selected in the bottom navigation bar.

Policies

- Software Settings
- Windows Settings
 - Name Resolution Policy**
 - Scripts (Startup/Shutdown)
 - Security Settings
 - Policy-based QoS
 - Administrative Templates: Policy def
- Preferences
- User Configuration
 - Policies
 - Preferences

Overview

The Name Resolution Policy Table (NRPT) stores configuration settings for DNS security (DNSSEC) and DirectAccess on DNS client computers. You can use this page to create or edit rules, which are used to make policies that can be applied to an Active Directory organizational unit (OU).

[Learn more about DNSSEC on the Web](#)

Description

Name Resolution Policy is the Group Policy object (GPO) that contains the policy information found in the Name Resolution Policy Table (NRPT).

Create Rules

To which part of the namespace does this rule apply?

Suffix: .zip

Certification authority: (Optional)

DNSSEC DNS Settings for DirectAccess Generic DNS Server Encoding

☒ Enable DNS settings

Generic DNS Server settings: 127.0.0.1

WORKS CITED

Bobbyr. (2023, May 16). *The Dangers of Google's .zip TLD*. Medium. <https://medium.com/@bobbyrsec/the-dangers-of-googles-zip-tld-5e1e675e59a5>

Chow, G. (2023, May 17). *Phishing Attacks Already Using the .zip TLD*. Netcraft. <https://www.netcraft.com/blog/phishing-attacks-already-using-the-zip-tld/>

Google. (2023, March 2). *Launch Details for Eight New TLDs*. Google Registry. <https://www.registry.google/announcements/launch-details-for-eight-new-tlds/>

ThioJoe. (2023, May 20). *Google Did Something REALLY Stupid - Protect Yourself!*. YouTube. <https://www.youtube.com/watch?v=GCVJsZ7EODA>

Ullrich, J. (2023, May 12). *The .zip gTLD: Risks and Opportunities*. Internet Storm Center. <https://isc.sans.edu/diary/The+.zip+gTLD:+Risks+and+Opportunities/29838>
